

FASE 0: Creare l'Ambiente Sicuro e Anonimo (OPSEC)

L'**OPSEC** (*Operational Security*, ovvero la Sicurezza Operativa) è l'insieme di precauzioni che prendi per non farti scoprire dal target, per non infettare il tuo computer reale e per non rivelare la tua vera identità.

1. Installa un Software di Virtualizzazione: Crea una bolla digitale isolata nel tuo computer. Installa un programma gratuito come **VirtualBox**. Questo software ti permette di creare una **Macchina Virtuale (VM)**, ovvero un "computer finto" che gira all'interno del tuo computer reale. Se durante l'indagine scarichi per sbaglio un file malevolo o apri un link trappola, l'infezione rimarrà chiusa dentro la Macchina Virtuale e non toccherà il tuo sistema operativo reale.

2. Scarica un Sistema Operativo dedicato all'OSINT: Linux gratuito e pre-configurato. Invece di usare Windows, scarica l'immagine ISO gratuita di una distribuzione Linux orientata all'OSINT e alla cybersecurity, come **Trace Labs OSINT VM** oppure **Tsurugi Linux** (sviluppata da esperti italiani). Entrambe contengono già centinaia di strumenti OSINT gratuiti pronti all'uso.

3. Configura la Connessione: VPN e/o Tor: Nascondi il tuo vero indirizzo IP. Il tuo **Indirizzo IP** (*Internet Protocol*) è la targa del tuo computer su Internet: rivela a quale città/provider appartieni. Quando visiti un sito o un profilo, il proprietario può vedere chi ha effettuato l'accesso.

- **ProtonVPN (Piano Free):** Una VPN cripta il tuo traffico e fa sembrare che tu ti stia connettendo da un'altra nazione. Il piano gratuito di Proton è illimitato e sicuro.
- **Tor Browser:** Se devi navigare su siti sospetti o verificare link senza che nessuno sappia chi sei, usa Tor Browser (gratuito).

4. Crea delle Identità Fittizie (Sock Puppets): Naviga sui social senza la tua vera identità. Non usare **mai** i tuoi profili social personali per cercare informazioni su un target. I social network consigliano amici in base ai profili visitati e tracciano le tue ricerche.

- Crea una mail anonima (es. su ProtonMail).
- Usa siti come thispersondoesnotexist.com (genera foto di persone finte tramite Intelligenza Artificiale) per la foto profilo.
- Crea account social "fantasma" (*Sock Puppets*) usati **solo** dentro la Macchina Virtuale per fare le tue ricerche.

FASE 1: Pianificazione e Identificazione del Target (Pivoting)

In questa fase definisci chi è il target e raccogli i suoi **Punti di Innesco** (*Pivot Points*), cioè le singole informazioni di partenza da cui dipanare la matassa:

- Nome e Cognome
- Un Indirizzo E-mail
- Un Numero di Telefono
- Un Username o Nickname usato online

- Un Indirizzo IP o Nome di Dominio (se il target è un'azienda o un sito)

Cosa significa "Pivoting"?

Il *Pivoting* è la tecnica fondamentale dell'OSINT. Consiste nel prendere un dato certo (es. un'e-mail) per scoprirne un altro (es. un nickname), e usare quel nickname per trovare un numero di telefono, e così via a catena.

FASE 2: Raccolta Dati (Step-by-Step con Strumenti Free)

Ora inizia l'indagine vera e propria. Procedi per strati, dal generale al particolare.

Step 1: Analisi di Google e Motori di Ricerca (Dorking)

L'analista non cerca semplicemente *"Mario Rossi"*, ma usa i **Google Dorks** (comandi avanzati per filtrare il rumore).

Plaintext

site:linkedin.com/in/ "Mario Rossi"

filetype:pdf "Mario Rossi"

"Mario Rossi" @gmail.com

- **site:** limita la ricerca a un singolo sito web.
- **filetype:** cerca solo file specifici (PDF, file Excel, documenti Word esposti per errore).
- Le virgolette "" costringono il motore a cercare la frase **esatta**.

Step 2: Caccia agli Username e Profili Social

Molte persone usano lo stesso *username* (o varianti simili) per iscriversi a decine di siti diversi (forum, videogiochi, social, e-commerce).

- **Strumento Gratuito: WhatsMyName** (whatsmyname.app) o **Sherlock** (strumento a riga di comando preinstallato in Tsurugi/Kali Linux).
- **Come funziona:** Inserisci un nickname (es. [mario_rossi_92](#)) e lo strumento interroga centinaia di siti web contemporaneamente, restituendoti l'elenco esatto di tutte le piattaforme in cui quell'username risulta registrato.

Step 3: Verifica delle E-mail e dei Breach Passati (Leak Data)

L'analista controlla se le e-mail del target sono state coinvolte in violazioni di dati storiche (*Data Breach*).

- **Strumento Gratuito: Have I Been Pwned** (haveibeenpwned.com).
- **Come funziona:** Inserisci la mail. Il sito ti dice se la mail e la relativa password sono state rubate in passato da siti come LinkedIn, Adobe, Canva, ecc. Questo ti permette di confermare che quell'indirizzo e-mail esiste davvero ed è attivo.

Step 4: Analisi delle Immagini e dei Metadati (EXIF)

Un'immagine dice molto più di quello che mostra visivamente.

1. **Ricerca Visiva Inversa:** Carica la foto del target su **Yandex Images** e **Google Lens**. Yandex ha il miglior algoritmo di riconoscimento facciale al mondo per trovare la stessa persona in altre foto su internet, anche con angolazioni diverse.
2. **Analisi Metadati EXIF:**
 - **Cosa sono gli EXIF?** Sono informazioni nascoste dentro i file fotografici generati dalle fotocamere o dagli smartphone (coordinate GPS esatte, data, ora, modello di telefono usato).
 - **Strumento Gratuito:** **Exiftool** o il sito jimpl.com. Carichi la foto ed estrai i dati geografici e tecnici.

Step 5: Mappatura delle Relazioni (OSINT Framework)

Invece di navigare a vista, l'analista consulta la mappa concettuale **OSINT Framework** (osintframework.com). Si tratta di un albero decisionale gratuito che ti guida dicendoti: *"Hai una mail? Clicca qui per vedere i 10 strumenti gratuiti esistenti per analizzare una mail."*

FASE 3: Elaborazione e Analisi dei Dati

Raccogliere 50 screenshot non serve a nulla se non colleghi i punti. L'analista usa uno strumento di organizzazione visiva.

- **Strumento Gratuito consigliato:** **Obsidian** oppure **OpenRefine**.
- **Cosa si fa:** Si crea una **linea del tempo (Timeline)** e una **mappa delle relazioni (Link Analysis)**.
 - **2018:** Mario Rossi crea l'account su un forum di auto con la mail A.
 - **2020:** Usa la stessa mail per un profilo Instagram con username B.
 - **2022:** Pubblica una foto su Flickr da cui estraiamo i metadati GPS della sua città.

FASE 4: Redazione del Report Finale

Un report professionale non contiene mai opinioni personali, ma solo **fatti documentati e verificabili**.

Struttura Standard del Report OSINT:

1. **Obiettivo:** Definizione chiara del soggetto d'indagine.
2. **Executive Summary:** 5-10 righe con i risultati chiave trovati (pensate per il cliente o il manager che non ha tempo di leggere tutto).
3. **Metodologia e Strumenti:** Elenco dei software usati (per garantire la ripetibilità dell'analisi).
4. **Dettaglio dei Risultati (con Prove):** Ogni affermazione deve essere supportata da uno screenshot con data/ora e dall'URL di origine stampato.
5. **Valutazione dei Rischi / Rimedi (Remediation):** Come il target può mettere al sicuro i propri dati eliminando le tracce esposte.

Glossario Tecnico Essenziale per Principianti

- **OPSEC:** Regole per non far capire a chi stai indagando che lo stai controllando.

- **Sock Puppet:** Un account social o un'identità fittizia usata solo per fare investigazioni.
- **Data Breach:** Il furto o la pubblicazione non autorizzata di database aziendali contenenti e-mail, nomi e password.
- **EXIF Data:** Dati tecnici nascosti dentro le immagini (GPS, data, modello di dispositivo).
- **Google Dorking:** L'uso di comandi avanzati nella barra di ricerca per trovare file e informazioni che Google ha indicizzato ma che i proprietari volevano tenere nascosti.